

ZAP by Checkmarx

Scanning Report

Generated with  ZAP on Fri 3 Jan 2025, at 11:19:13

ZAP Version: 2.15.0

ZAP by [Checkmarx](#)

Contents

- [About this report](#)
 - [Report parameters](#)
- [Summaries](#)
 - [Alert counts by risk and confidence](#)
 - [Alert counts by site and risk](#)
 - [Alert counts by alert type](#)
- [Alerts](#)
 - [Risk=High, Confidence=Medium \(1\)](#)
 - [Risk=Medium, Confidence=High \(1\)](#)
 - [Risk=Medium, Confidence=Medium \(2\)](#)
 - [Risk=Low, Confidence=High \(1\)](#)
 - [Risk=Low, Confidence=Medium \(3\)](#)

- [Risk=Low, Confidence=Low \(1\)](#).
- [Risk=Informational, Confidence=Medium \(1\)](#).
- [Risk=Informational, Confidence=Low \(2\)](#).
- [Appendix](#)
 - [Alert types](#)

About this report

Report parameters

Contexts

No contexts were selected, so all contexts were included by default.

Sites

The following sites were included:

- <https://update.googleapis.com>
- <https://optimizationguide-pa.googleapis.com>
- <https://content-autofill.googleapis.com>
- <http://127.0.0.1:8000>
- <https://accounts.google.com>

(If no sites were selected, all sites were included by default.)

An included site must also be within one of the included contexts for its data to be included in the report.

Risk levels

Included: [High](#), [Medium](#), [Low](#), [Informational](#)

Excluded: None

Confidence levels

Included: User Confirmed, High, Medium, Low

Excluded: User Confirmed, High, Medium, Low, False Positive

Summaries

Alert counts by risk and confidence

This table shows the number of alerts for each level of risk and confidence included in the report.

(The percentages in brackets represent the count as a percentage of the total number of alerts included in the report, rounded to one decimal place.)

		Confidence				
Risk		User Confirmed	High	Medium	Low	Total
	High	0 (0.0%)	0 (0.0%)	1 (8.3%)	0 (0.0%)	1 (8.3%)
	Medium	0 (0.0%)	1 (8.3%)	2 (16.7%)	0 (0.0%)	3 (25.0%)
	Low	0 (0.0%)	1 (8.3%)	3 (25.0%)	1 (8.3%)	5 (41.7%)
	Informational	0 (0.0%)	0 (0.0%)	1 (8.3%)	2 (16.7%)	3 (25.0%)
	1					
	Total	0 (0.0%)	2 (16.7%)	7 (58.3%)	3 (25.0%)	12 (100%)

Alert counts by site and risk

This table shows, for each site for which one or more alerts were raised, the number of alerts raised at each risk level.

Alerts with a confidence level of "False Positive" have been excluded from these counts.

(The numbers in brackets are the number of alerts raised for the site at or above that risk level.)

	Risk				Informational
	High (= High)	Medium (>= Medium)	Low (>= Low)	(>= Informational)	
Site https://optimizationguide-pa.googleapis.com	0 (0)	0 (0)	1 (1)	0 (1)	
https://content-autofill.googleapis.com	0 (0)	0 (0)	1 (1)	1 (2)	
http://127.0.0.1:8000	1 (1)	3 (4)	3 (7)	2 (9)	

Alert counts by alert type

This table shows the number of alerts of each alert type, together with the alert type's risk level.

(The percentages in brackets represent each count as a percentage, rounded to one decimal place, of the total number of alerts included in this report.)

Alert type	Risk	Count
Vulnerable JS Library	High	1 (8.3%)
Content Security Policy (CSP) Header Not Set	Medium	9 (75.0%)
Total		12

Alert type	Risk	Count
Missing Anti-clickjacking Header	Medium	9 (75.0%)
Vulnerable JS Library	Medium	2 (16.7%)
Cookie No HttpOnly Flag	Low	1 (8.3%)
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	1 (8.3%)
Strict-Transport-Security Header Not Set	Low	12 (100.0%)
Timestamp Disclosure - Unix	Low	6 (50.0%)
X-Content-Type-Options Header Missing	Low	23 (191.7%)
Information Disclosure - Suspicious Comments	Informational	6 (50.0%)
Re-examine Cache-control Directives	Informational	9 (75.0%)
Session Management Response Identified	Informational	3 (25.0%)
Total		12

Alerts

Risk=High, Confidence=Medium (1)

<http://127.0.0.1:8000> (1)

Vulnerable JS Library (1)

► GET <http://127.0.0.1:8000/assets/modules/moment.min.js>

Risk=Medium, Confidence=High (1)

<http://127.0.0.1:8000> (1)

Content Security Policy (CSP) Header Not Set (1)

► GET <http://127.0.0.1:8000/>

Risk=Medium, Confidence=Medium (2)

<http://127.0.0.1:8000> (2)

Missing Anti-clickjacking Header (1)

► GET <http://127.0.0.1:8000/>

Vulnerable JS Library (1)

► GET <http://127.0.0.1:8000/assets/modules/jquery.min.js>

Risk=Low, Confidence=High (1)

<https://content-autofill.googleapis.com> (1)

Strict-Transport-Security Header Not Set (1)

► GET <https://content-autofill.googleapis.com/v1/pages/ChVDAhJvbWUvMTMxLjAuNjc3OC4yMDUSIAAn0gagCwSOEEBIFDY0oWz0SBQ30QUx6IXrWnZWmkt8g?alt=proto>

Risk=Low, Confidence=Medium (3)

<http://127.0.0.1:8000> (3)

Cookie No HttpOnly Flag (1)

► GET <http://127.0.0.1:8000/>

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) (1)

► GET <http://127.0.0.1:8000/>

X-Content-Type-Options Header Missing (1)

► GET
<http://127.0.0.1:8000/assets/modules/fontawesome/css/all.min.css>
s

Risk=Low, Confidence=Low (1)

<https://optimizationguide-pa.googleapis.com> (1)

Timestamp Disclosure - Unix (1)

► POST <https://optimizationguide-pa.googleapis.com/v1:GetModels?key=AIzaSyB0ti4mM-6x9WDnZIjIeyEU210pBXqWBgw>

Risk=Informational, Confidence=Medium (1)

<http://127.0.0.1:8000> (1)

Session Management Response Identified (1)

► GET http://127.0.0.1:8000/

Risk=Informational, Confidence=Low (2)

<https://content-autofill.googleapis.com> (1)

Re-examine Cache-control Directives (1)

► GET https://content-autofill.googleapis.com/v1/pages/ChVDaHJvbWUvMTMxLjAuNjc3OC4yMDUSIAAn0gagCwSOEEBIFDY0oWz0SBQ30QUx6IXrWnZWmkt8g?alt=proto

<http://127.0.0.1:8000> (1)

Information Disclosure - Suspicious Comments (1)

► GET http://127.0.0.1:8000/assets/modules/jquery.min.js

Appendix

Alert types

This section contains additional information on the types of alerts in the report.

Vulnerable JS Library

Source raised by a passive scanner ([Vulnerable JS Library \(Powered by Retire.js\)](#))

CWE ID [1395](#)

Reference [https://cwe.mitre.org/data/definitions/1395.html](#)

[advisories/GHSA-wc69-rhjr-hc9g](#)

- <https://security.snyk.io/vuln/SNYK-JS-MOMENT-2944238>
- <https://github.com/moment/moment/security/advisories/GHSA-8hfj-j24r-96c4>

Content Security Policy (CSP) Header Not Set

Source	raised by a passive scanner (Content Security Policy (CSP) Header Not Set)
CWE ID	693
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/Security/CSP/Introducing_Content_Security_Policy ▪ https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html ▪ https://www.w3.org/TR/CSP/ ▪ https://w3c.github.io/webappsec-csp/ ▪ https://web.dev/articles/csp ▪ https://caniuse.com/#feat=contentsecuritypolicy ▪ https://content-security-policy.com/

Missing Anti-clickjacking Header

Source	raised by a passive scanner (Anti-clickjacking Header)
CWE ID	1021
WASC ID	15
Reference	▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options

Vulnerable JS Library

Source	raised by a passive scanner (Vulnerable JS Library (Powered by Retire.js))
CWE ID	1395
Reference	▪ https://blog.jquery.com/2019/04/10/jquery-3-4-0-released/ ▪ https://nvd.nist.gov/vuln/detail/CVE-2019-11358 ▪ https://github.com/jquery/jquery/commit/753d591aea698e57d6db58c9f722cd0808619b1b ▪ https://blog.jquery.com/2020/04/10/jquery-3-5-0-released/

Cookie No HttpOnly Flag

Source	raised by a passive scanner (Cookie No HttpOnly Flag)
CWE ID	1004
WASC ID	13

Reference

- <https://owasp.org/www-community/HttpOnly>

Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)**Source**

raised by a passive scanner ([Server Leaks Information via "X-Powered-By" HTTP Response Header Field\(s\)](#))

CWE ID

[200](#)

WASC ID

13

Reference

- https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework
- <https://www.troyhunt.com/2012/02/shhh-dont-let-your-response-headers.html>

Strict-Transport-Security Header Not Set**Source**

raised by a passive scanner ([Strict-Transport-Security Header](#))

CWE ID

[319](#)

WASC ID

15

Reference

- https://cheatsheetseries.owasp.org/cheatsheets/HTTP_Strict_Transport_Security_Cheat_Sheet.html
- <https://owasp.org/www-community/Security-Headers>

- https://en.wikipedia.org/wiki/HTTP_Strict_Transport_Security
- <https://caniuse.com/stricttransportsecurity>
- <https://datatracker.ietf.org/doc/html/rfc6797>

Timestamp Disclosure - Unix

Source	raised by a passive scanner (Timestamp Disclosure)
CWE ID	200
WASC ID	13
Reference	■ https://cwe.mitre.org/data/definitions/200.html

X-Content-Type-Options Header Missing

Source	raised by a passive scanner (X-Content-Type-Options Header Missing)
CWE ID	693
WASC ID	15
Reference	■ https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) ■ https://owasp.org/www-community/Security-Headers

Information Disclosure - Suspicious Comments

Source	raised by a passive scanner (Information Disclosure - Suspicious Comments)
CWE ID	200
WASC ID	13

Re-examine Cache-control Directives

Source	raised by a passive scanner (Re-examine Cache-control Directives)
CWE ID	525
WASC ID	13
Reference	▪ https://cheatsheetseries.owasp.org/cheatsheets/Session_Management_Cheat_Sheet.html#web-content-caching ▪ https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cache-Control ▪ https://grayduck.mn/2021/09/13/cache-control-recommendations/

Session Management Response Identified

Source	raised by a passive scanner (Session Management Response Identified)
Reference	▪ https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id